DOSSIER TECHNIQUE · VERSION 1.0.22

KoliGo : architecture, modèles et flux

Document du 21/10/2026 Branche php-backend Schéma de données v22

Production : koligo.trugroup.cm

01 Synthèse

KoliGo est une plateforme de livraison collaborative au Cameroun. Un vendeur en ligne publie une course avec trois prix croissants, un livreur de proximité l'accepte, et le destinataire paie en Mobile Money à la livraison en donnant un code unique. Une place de marché d'annonces (Flash gratuites 24 h, Boost payantes) complète le service.

3
interfaces : application Android, back-office web, site vitrine

176
routes déclarées dans l'API (`routes.php`)

37
tables, schéma versionné (v22)

8 + 22
contrôleurs et services PHP

6
services externes : paiement, push, SMS, e-mail, cartes, WhatsApp

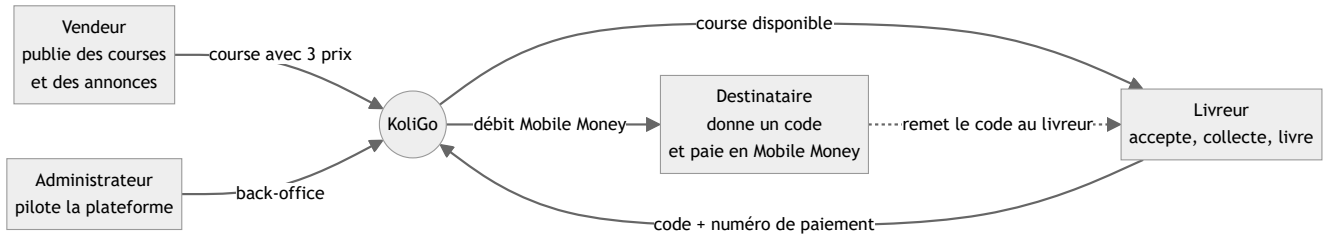
1.0.22
version de l'application (build 23)

Ce dossier décrit l'architecture telle qu'elle est dans le code au 21/10/2026 (branche `php-backend`). Les chiffres viennent des fichiers du dépôt. Ce qui n'a pas pu être vérifié depuis le code, comme la configuration réelle du serveur de production, est signalé comme tel.

COMPOSANT	TECHNOLOGIE	EMPLACEMENT
Application mobile	Expo SDK 51, React Native 0.74, React Navigation, i18next, Zustand, TanStack Query	`mobile/`
API	PHP 8.1 sans Composer, PDO (MySQL en production, SQLite en local)	`backend-php/`
Back-office	React 18, React Router, TanStack Query, Vite	`backoffice/`, servi sur `/admin/`
Site vitrine	HTML statique, lien de téléchargement piloté par l'API	`backend-php/landing/`
Ancien serveur	Node.js, Express, Prisma. Remplacé par le PHP, conservé dans le dépôt.	`backend/`
Hébergement	Mutualisé Camoo, déploiement par FTP, domaine `koligo.trugroup.cm`	production

02 Acteurs et cas d'usage

Quatre rôles interagissent. Le destinataire n'a pas besoin de l'application : il donne un code et un numéro Mobile Money au livreur.

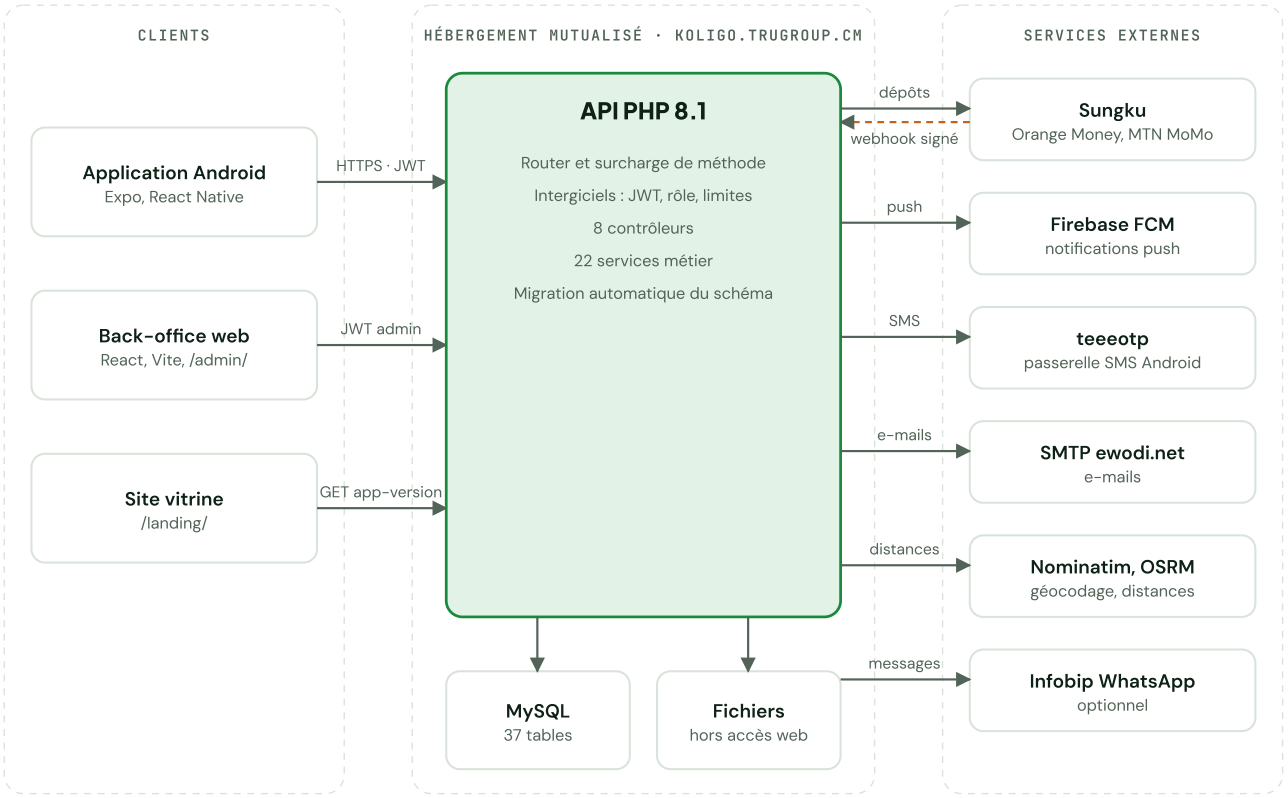


Les rôles et leurs échanges avec la plateforme. Le destinataire n'utilise pas l'application.

RÔLE	PEUT FAIRE	CONTRÔLES
Vendeur	Publier une course avec trois prix, répondre aux demandes de nouveau prix, annuler, publier des annonces Flash ou Boost, suivre ses incidents	KYC validé, suspension après 3 incidents confirmés
Livreur	Voir les courses disponibles, accepter, confirmer la conformité du colis, signaler son arrivée, encaisser avec le code de l'acheteur, retirer ses gains	KYC validé, type de livreur (temporaire ou permanent), véhicule
Destinataire	Recevoir le colis, donner son code et son numéro Mobile Money	Aucun compte
Administrateur	KYC, tarification, utilisateurs et PIN, annonces, incidents, paiements Boost, versions de l'application, notifications, SMS	Connexion par e-mail et mot de passe, journal des actions (`AdminAction`)

03 Architecture d'ensemble

Une seule API PHP sert tous les clients. Elle parle à une base MySQL et à six services externes. Aucun service externe ne reçoit de données dont il n'a pas besoin : Sungku reçoit un montant et un numéro, teeeotp un numéro et un texte court, Firebase un jeton d'appareil et un message.



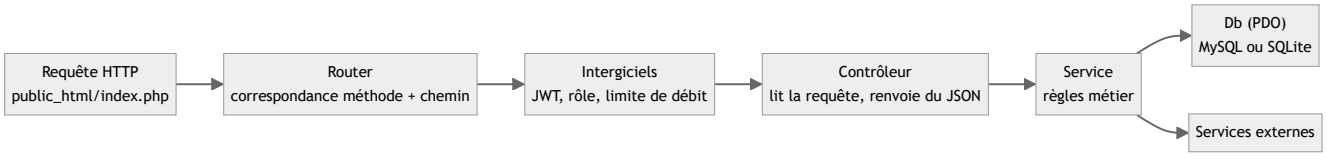
Vue d'ensemble : les trois clients, l'API sur l'hébergement mutualisé, la base et les fichiers, et les six services externes. Le trait pointillé est l'appel entrant de Sungku. Les notifications Firebase arrivent ensuite sur le téléphone.

Principes de conception

- **Une API, plusieurs clients.** Les routes existent avec et sans le préfixe `/api`, pour rester compatibles avec l'ancien serveur Node.
- **Hébergement contraint, code adapté.** Pas de Composer, pas de tâche planifiée garantie, Apache refuse PUT, PATCH et DELETE, et un pare-feu bloque le texte `data:image` dans les corps de requête. Le code contourne chacune de ces limites (voir la section suivante).
- **La base est la source de vérité.** Les transitions d'état sont des `UPDATE … WHERE status = …` atomiques : un rejeu ou deux requêtes simultanées ne produisent qu'un effet.
- **Un service externe en panne ne bloque pas le métier.** Les notifications, SMS et e-mails sont « au mieux » : leur échec est journalisé, pas propagé.

04 Architecture du serveur

Le serveur est une application PHP 8.1 sans bibliothèque externe. Une requête traverse quatre couches.



Chemin d'une requête. Les contrôleurs restent fins : les règles métier vivent dans les services.

COUCHE	FICHIERS	RÔLE
Entrée	`public_html/index.php`, `.htaccess`	Point unique, réécriture d'URL, surcharge de méthode
Noyau	`Router`, `Http`, `Db`, `Env`, `Jwt`, `Auth`, `RateLimit`, `Setup`	Routage, JSON, PDO, configuration, jetons, limites, migrations
Contrôleurs (8)	Admin, Annonce, Auth, Delivery, Notification, Payment, Public, Wallet	Traduisent HTTP vers appels de services
Services (22)	Accounts, AdminLogin, Annonces, AppVersions, Cgu, Deliveries, Distance, FixedRoutes, Incidents, Invoices, Kyc, KycChecks, MailTemplate, Moderation, Notifier, Notify, Payments, Pricing, Sms, Smtp, Sungku, Uploads	Règles métier et clients des services externes
Données	`app/database/schema.sql`, `geo.json`, `cgu_default.php`	Schéma, 17 villes et 270 quartiers, texte des CGU

Contraintes de l'hébergement et réponses

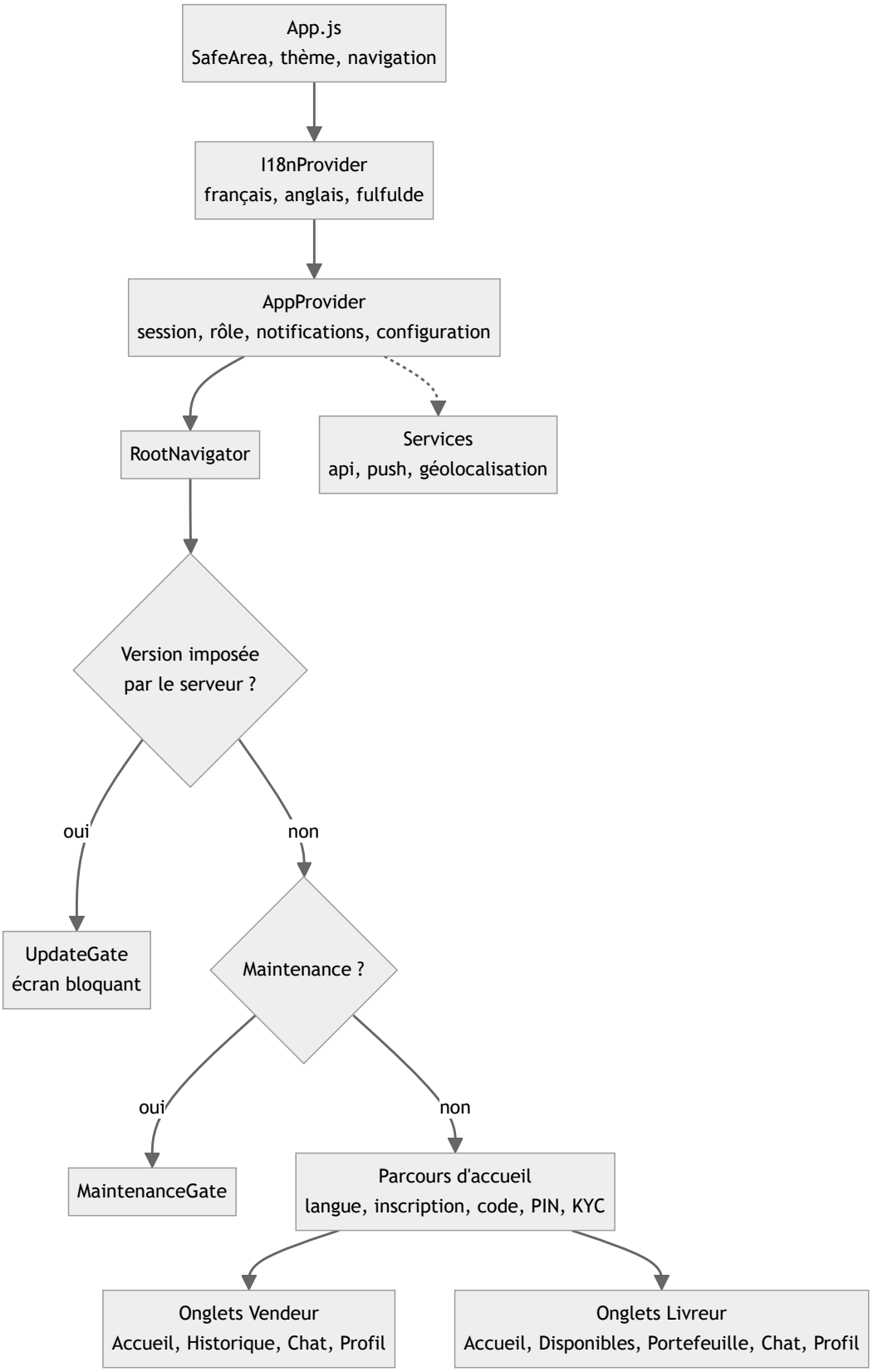
CONTRAINTE	CONSÉQUENCE	RÉPONSE DANS LE CODE
Apache rejette PUT, PATCH, DELETE avant PHP	Les clients ne peuvent pas utiliser ces verbes	Les clients envoient `POST` avec un en-tête de surcharge de méthode, relu par le routeur
Pare-feu : 403 sur le texte `data:image`	Les photos en data URI sont refusées	L'application envoie le base64 brut, sans préfixe
Pas de Composer	Pas de bibliothèques	Clients HTTP, SMTP et JWT écrits à la main, liste de classes explicite dans `bootstrap.php`
Aucune tâche planifiée garantie	Pas de travail périodique fiable	Travail « paresseux » après réponse : `register_shutdown_function` puis `fastcgi_finish_request`, déclenché par l'activité (KYC, revérification des paiements)
Redirection http vers https	Un POST redirigé perd son corps	Les URL des services externes sont forcées en https
Déploiement par FTP, parfois instable	Déploiements partiels possibles	Envoi fichier par fichier avec reprise, vérification de la taille côté serveur

Migration automatique

`Setup::ensureSchema()` compare `SCHEMA_VERSION` (actuellement 22) à la valeur stockée dans `PlatformSetting`. Si elle est plus ancienne, le schéma est rejoué (`CREATE TABLE IF NOT EXISTS`, ajout de colonnes, index) et les données de référence sont mises à jour. Un déploiement de code suffit : il n'y a pas de commande de migration à lancer.

05 Application mobile

Application Android construite avec Expo SDK 51 (React Native 0.74), compilée en APK par Gradle. Le code est dans `mobile/src`.



Démarrage de l'application : deux portes (mise à jour imposée, maintenance) avant le parcours d'accueil puis les onglets du rôle actif.

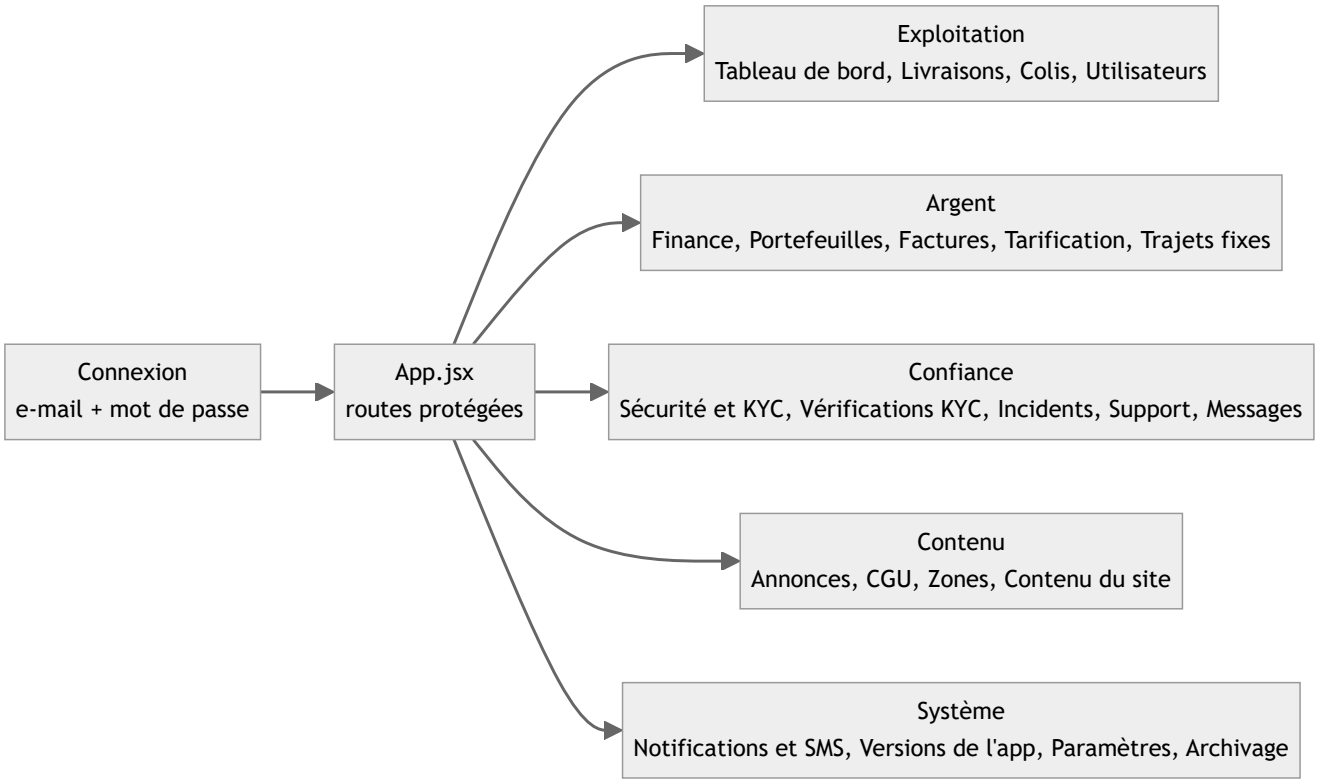
DOMAINE	CHOIX	DÉTAIL
Navigation	React Navigation 6	Une pile racine (49 écrans déclarés) et deux navigateurs à onglets, un par rôle
État	Contexte React + Zustand	`AppContext` : session, rôle actif, notifications (relève toutes les 20 s), configuration et version (toutes les 60 s)
Réseau	Axios + `apiFetch`	Jeton d'accès, renouvellement par jeton de rafraîchissement, surcharge de méthode, délai de 15 s
Stockage sûr	expo-secure-store	Jetons et paramètres de session ; biométrie par expo-local-authentication
Notifications	expo-notifications + Firebase	Jeton FCM de l'appareil enregistré sur le profil ; relève de secours si le push n'est pas disponible
Langues	i18next, react-i18next	Clé = texte français ; dictionnaires anglais séparés ; fulfulde presque vide (3 textes sur 668)
Cartes et position	react-native-maps, expo-location	Position du livreur pendant la course
Images	expo-image-picker, expo-image-manipulator	Photos des colis, annonces, pièces KYC, envoyées en base64 brut

Écrans par domaine

DOSSIER	CONTENU
`screens/onboarding`	Langue, bienvenue, inscription, code de vérification, PIN, connexion, PIN oublié, KYC, localisation, choix du rôle, paiement
`screens/vendor`	Publier une course (trois prix), détail, codes, factures, incidents
`screens/deliverer`	Courses disponibles, confirmation de conformité, attente et encaissement, portefeuille
`screens/ads`	Fil d'annonces, détail, publier une annonce, mes annonces
`screens/shared`	Notifications, changement de PIN, chat, profil
`screens/client`	Suivi côté destinataire

06 Back-office

Application web React 18 compilée par Vite et déposée dans `/admin/`. Elle appelle les routes `/admin/*` de la même API avec un jeton d'administrateur. Connexion par e-mail et mot de passe, avec code par e-mail à la première connexion.



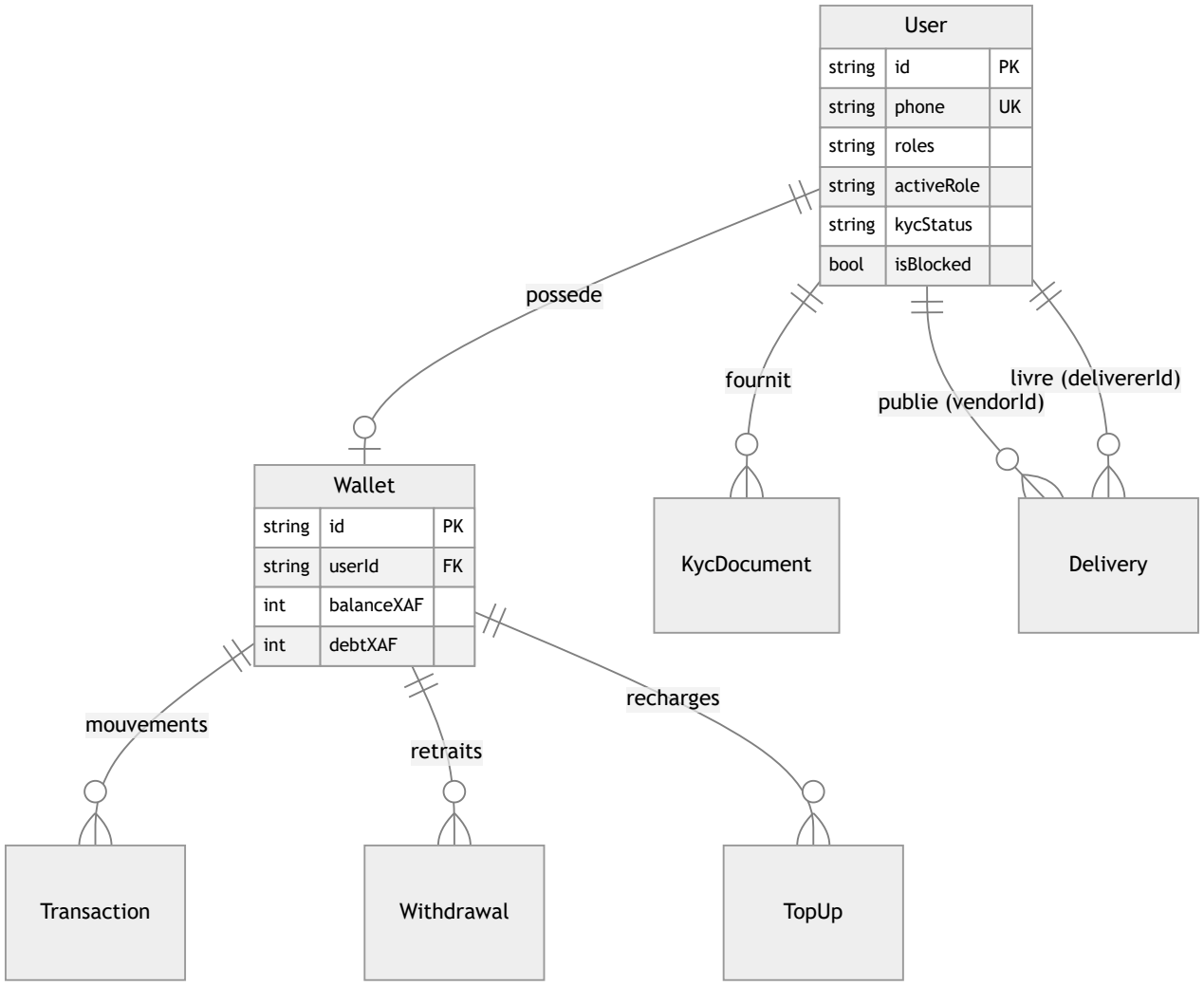
Les modules du back-office regroupés par métier.

MODULE	FONCTION
Utilisateurs	Fiche, KYC, réinitialiser ou verrouiller le PIN, suspendre, générer et envoyer un code OTP
Vérifications KYC	Historique des contrôles automatiques, relance, mode AUTO, SUGGEST ou OFF
Tarification	Commission, plancher des offres, frais d'annulation, délais, seuils d'incidents, zones et gabarits
Annonces	Modération, signalements, tarifs Boost, suivi des paiements Boost, validation manuelle sur preuve
Notifications	Messages aux utilisateurs, passerelle SMS (clé, test, journal), diagnostic e-mail
Versions de l'app	Historique des APK, version active, mise à jour obligatoire ou facultative, retour arrière
CGU	Publication des conditions, texte recommandé, versions

07 Modèle de données

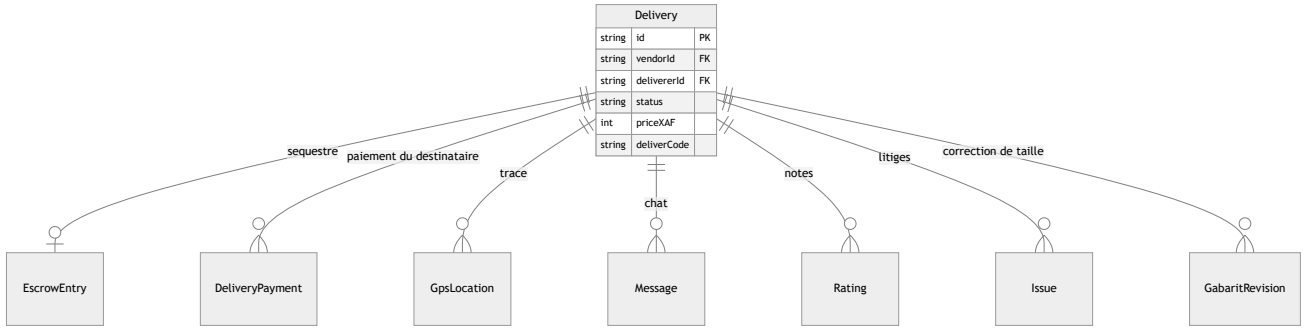
MySQL (InnoDB, utf8mb4) en production, SQLite en local et en test, avec le même fichier de schéma. Les identifiants sont des chaînes générées par l'application. Les dates sont en UTC. Les montants sont des entiers en francs CFA (XAF), sans décimales.

Comptes et argent

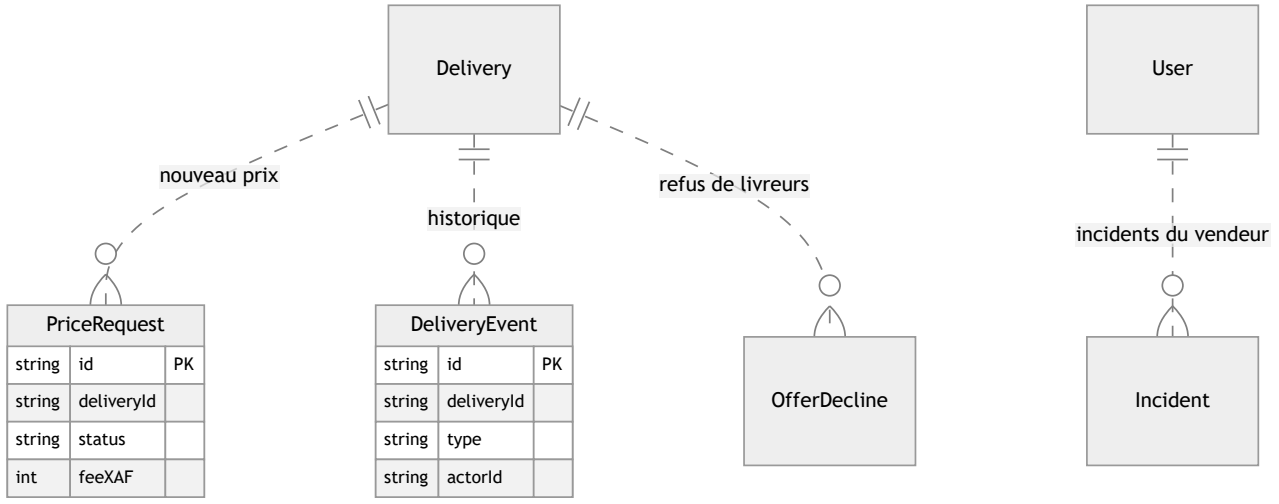


Un utilisateur a un portefeuille, des pièces KYC, et peut publier ou livrer des courses. Les montants du portefeuille évoluent par transactions, retraits et recharges.

Une course et ce qui s'y rattache

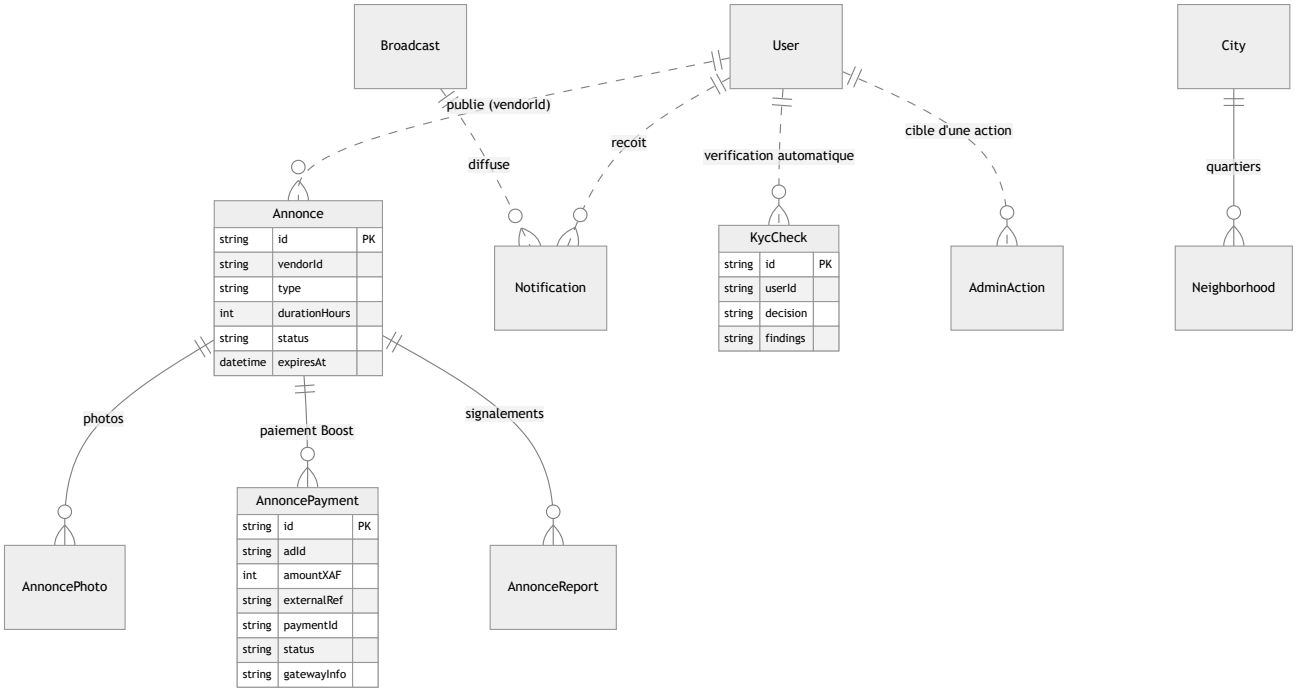


Tous les liens de ce schéma sont des clés étrangères déclarées dans le schéma SQL.



Liens logiques par identifiant, sans clé étrangère : la demande de nouveau prix, l'historique des événements, les refus de livreurs et les incidents.

Annonces, notifications, KYC et exploitation



Les annonces et leurs paiements, les notifications, les contrôles KYC et le référentiel géographique.

Les 37 tables par domaine

DOMAINE	TABLES
Comptes et sécurité	`User` , `OtpCode` , `RateLimit` , `KycDocument` , `KycCheck` , `AdminAction`

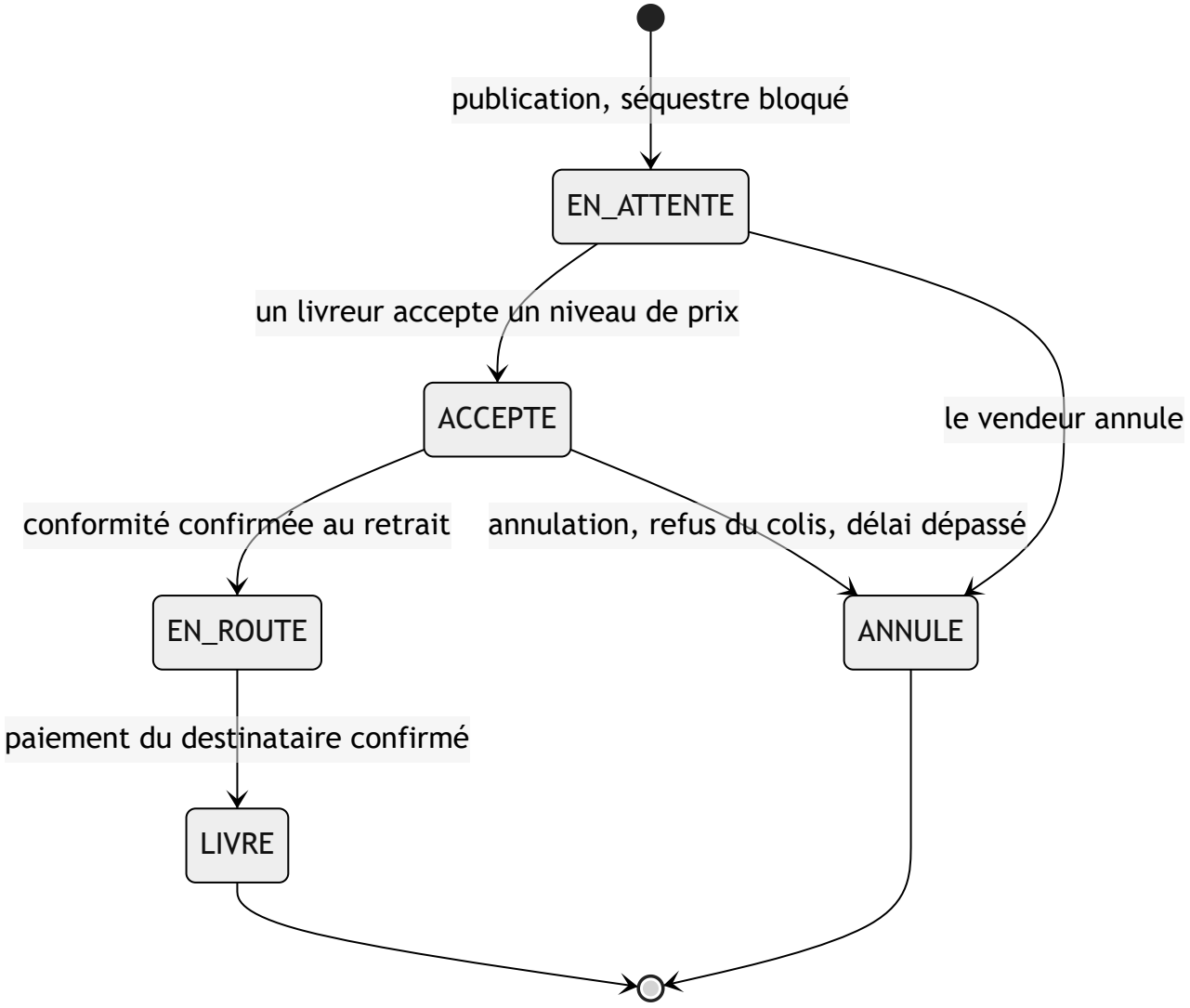
DOMAINE	TABLES
Courses	`Delivery`, `DeliveryEvent`, `PriceRequest`, `GabaritRevision`, `OfferDecline`, `GpsLocation`, `Message`, `Rating`, `Issue`, `Incident`
Argent	`Wallet`, `Transaction`, `EscrowEntry`, `Withdrawal`, `TopUp`, `DeliveryPayment`
Annonces	`Annonce`, `AnnoncePhoto`, `AnnoncePayment`, `AnnonceReport`
Tarification et géographie	`PlatformSetting`, `FixedRoute`, `City`, `Neighborhood`, `RouteCache`
Communication	`Notification`, `Broadcast`, `SmsLog`
Exploitation	`AppVersion`, `CguVersion`, `DbArchive`

`PlatformSetting` est une table clé-valeur qui porte la configuration modifiable au back-office (commission, délais, seuils, mode maintenance) et quelques états techniques (version du schéma, jeton Firebase en cache, clé de la passerelle SMS).

08 Machines à états

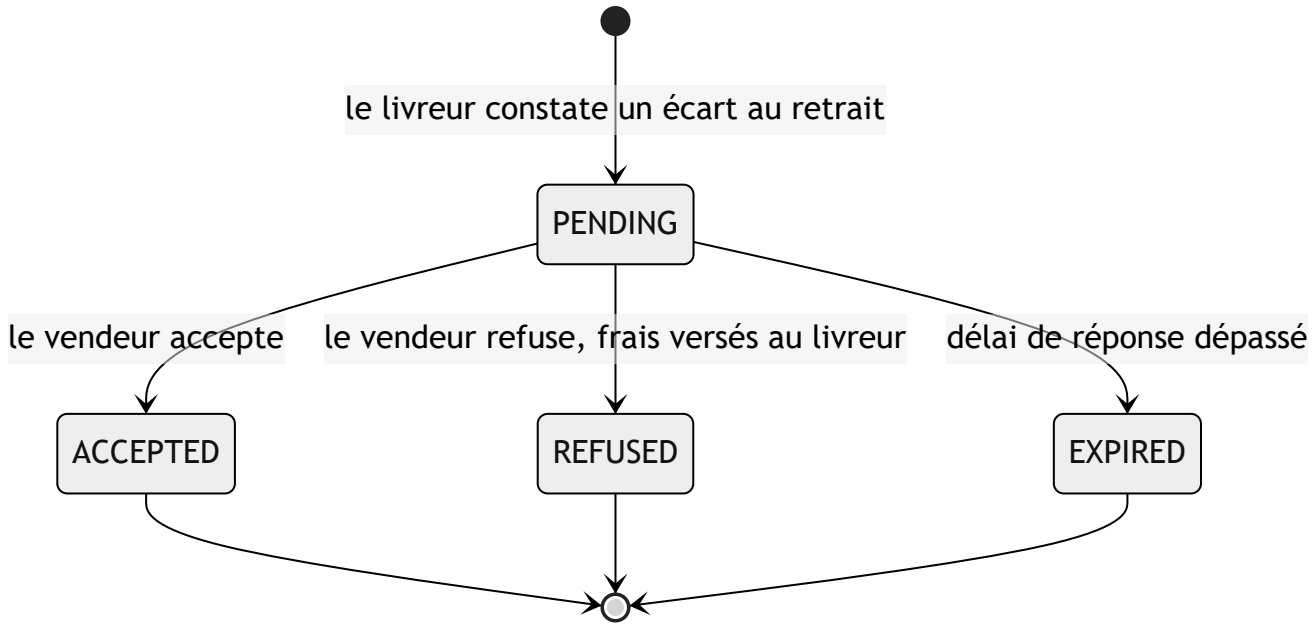
Chaque objet à cycle de vie suit un petit automate. Les transitions sont conditionnelles en base (`WHERE status = …`) : une transition impossible n'a aucun effet.

Course



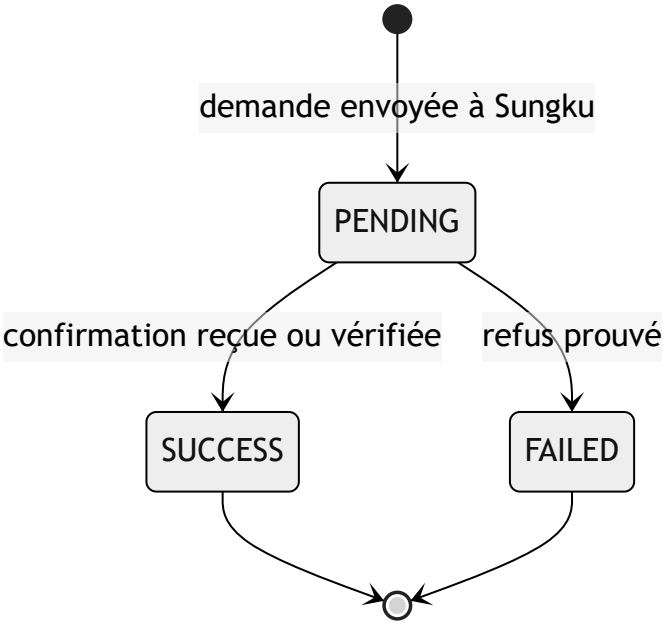
Statuts de `Delivery.status`. Le passage à LIVRE se fait seulement après confirmation du paiement par Sungku.

Demande de nouveau prix



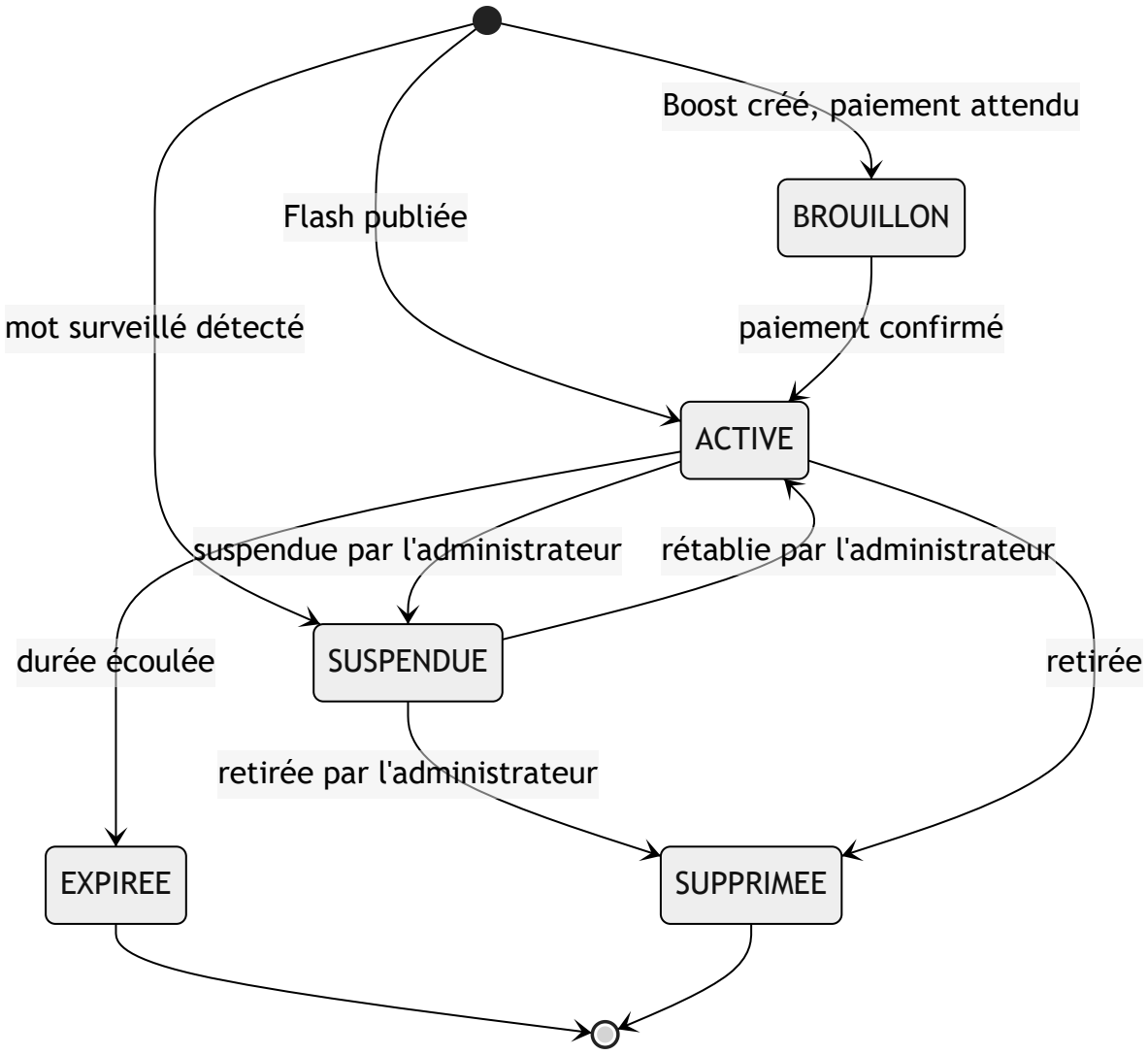
La même logique s'applique à la correction de taille (`GabaritRevision`). Un refus ou une expiration annule la course.

Paiement Mobile Money



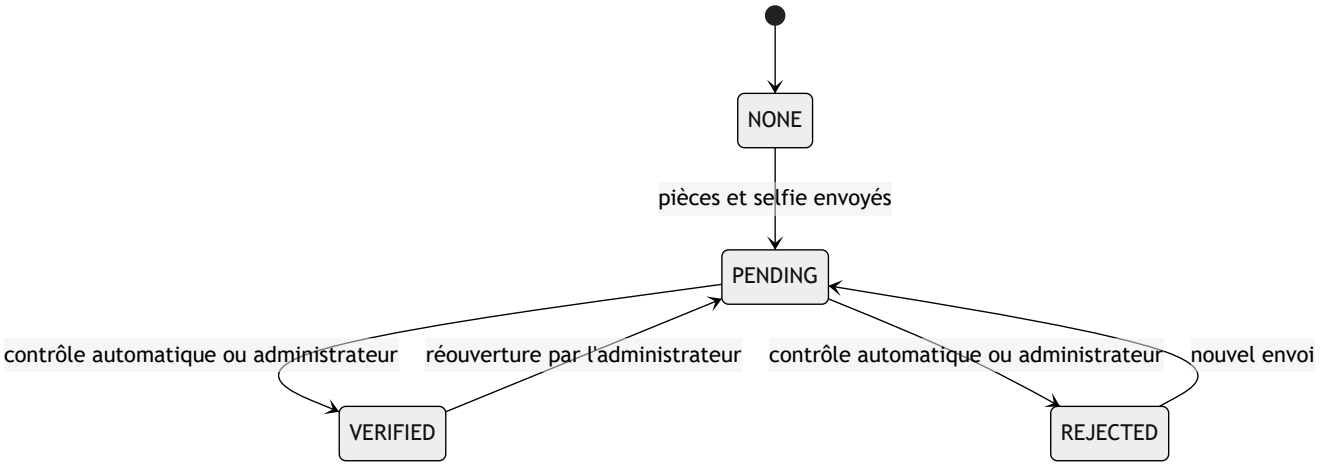
Un échec n'est conclu que s'il est prouvé. Un délai d'attente ou une erreur réseau laisse le paiement en PENDING, car l'argent a peut-être bougé.

Annonce



Statuts de `Annonce.status`. L'expiration est appliquée à la lecture (`status = ACTIVE AND expiresAt > maintenant`), sans tâche planifiée.

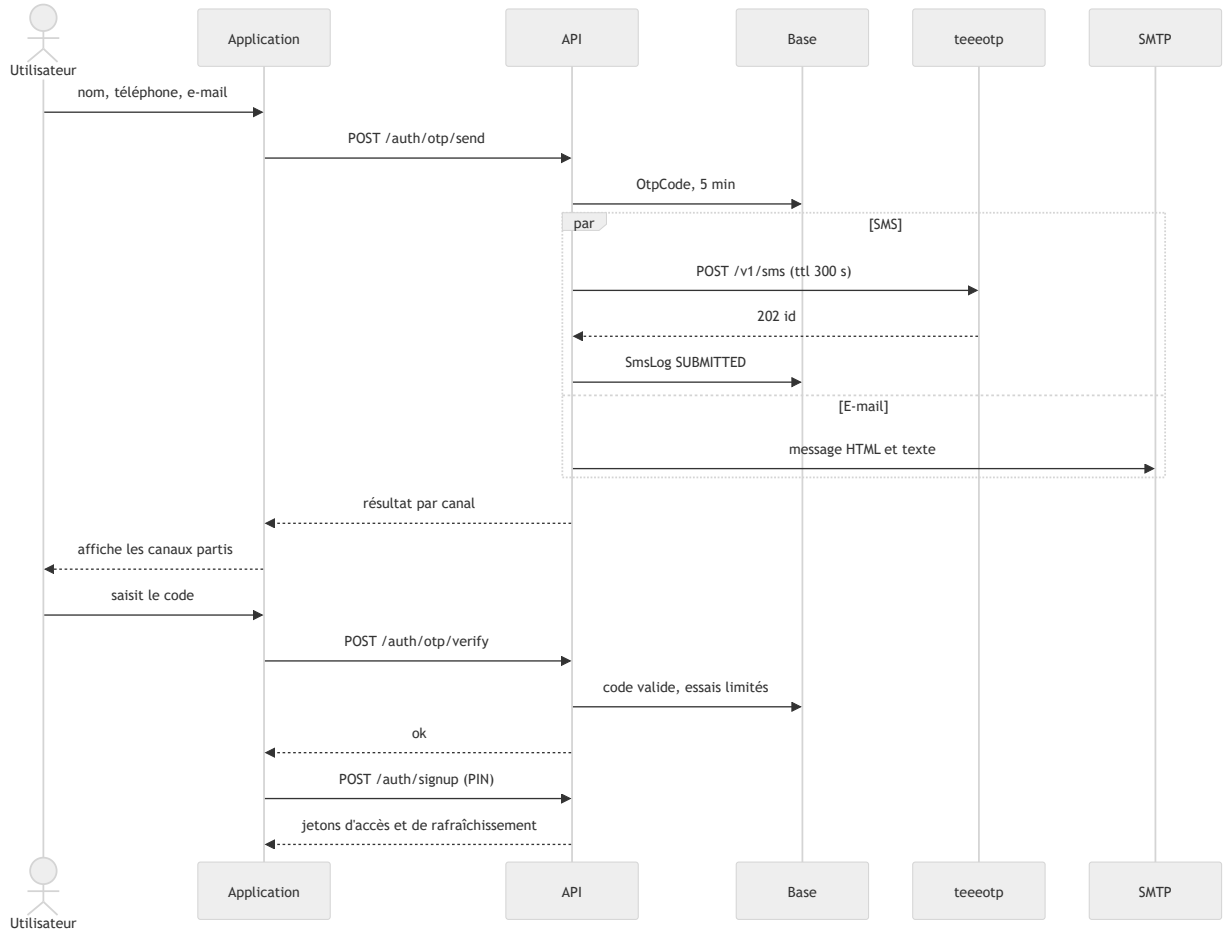
Vérification d'identité (KYC)



Statuts de `User.kycStatus`.

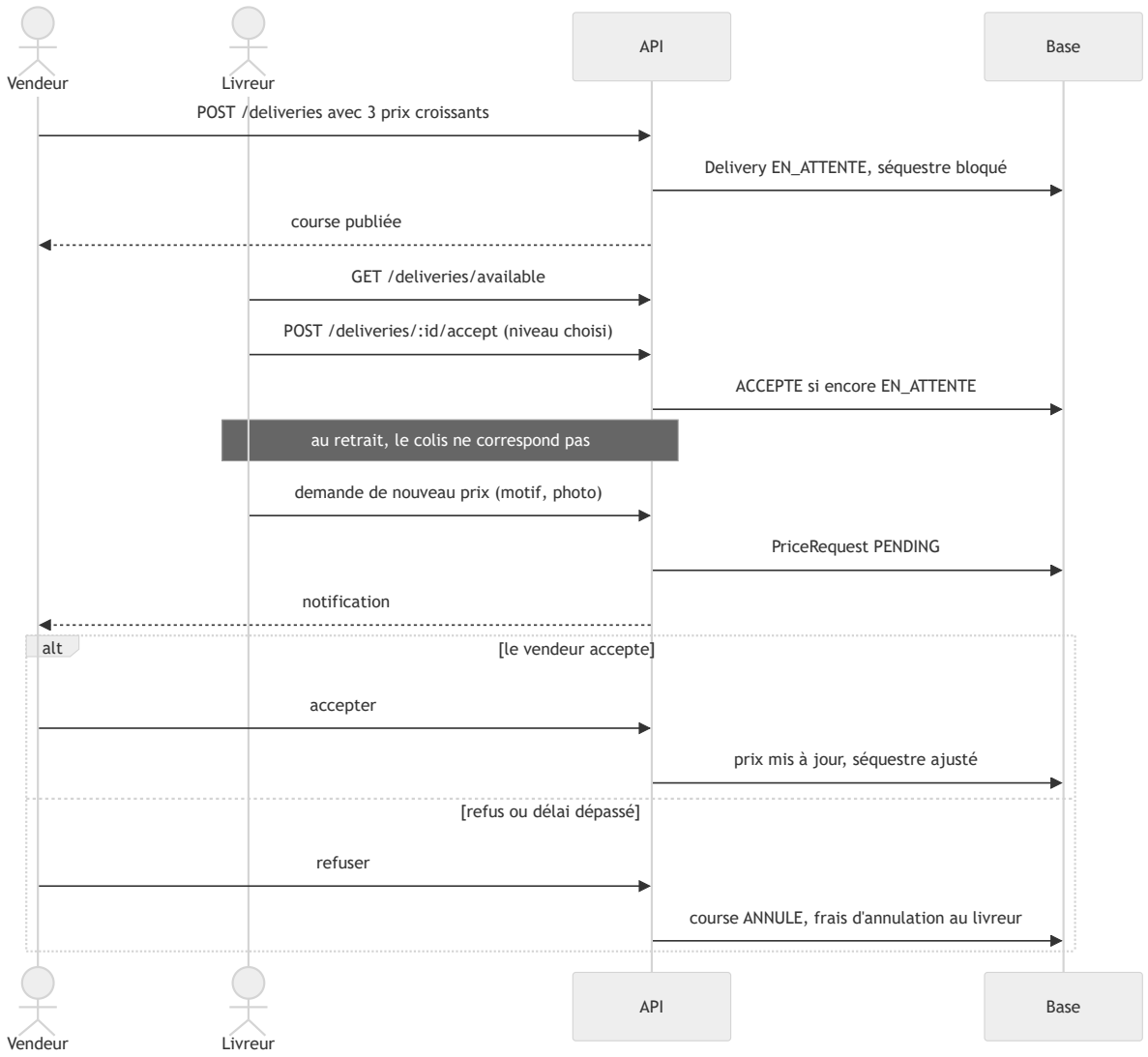
09 Flux métier

Inscription et code de vérification



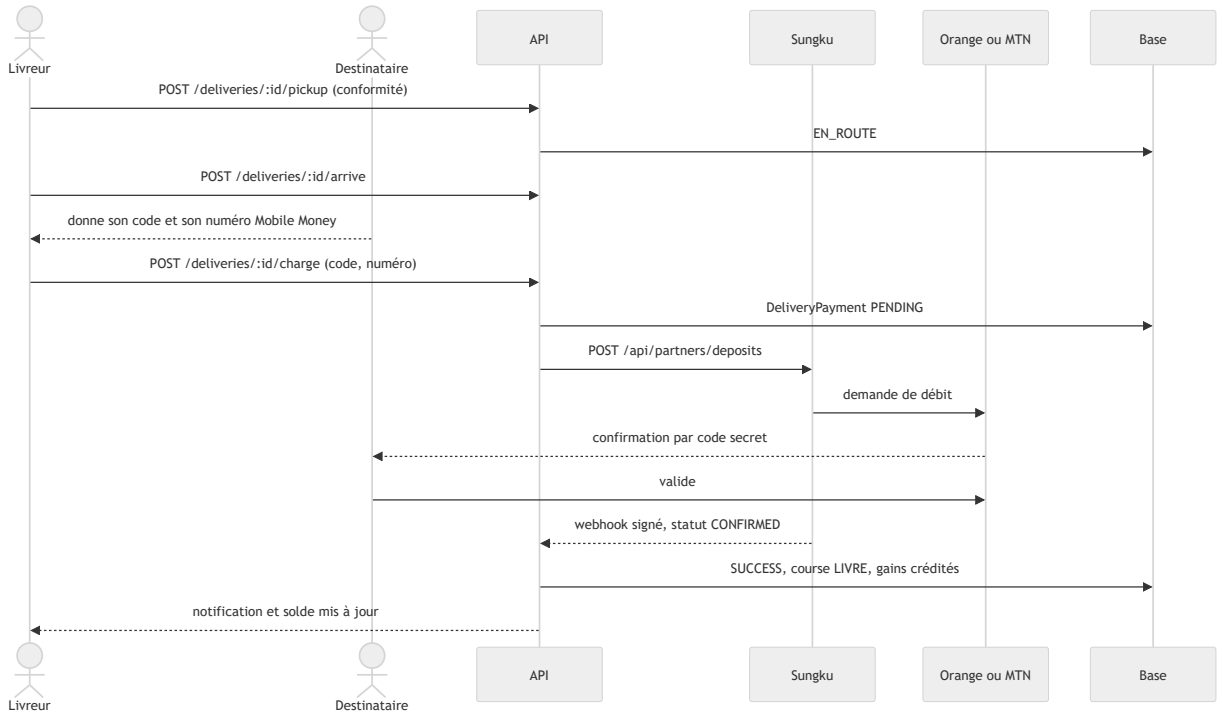
Le serveur répond avec le résultat réel de chaque canal. Le code peut aussi être généré et envoyé à un utilisateur précis depuis le back-office.

Publication et négociation du prix



Le vendeur fixe trois prix. Si le colis diffère de la description, le livreur propose un nouveau prix que le vendeur accepte ou refuse.

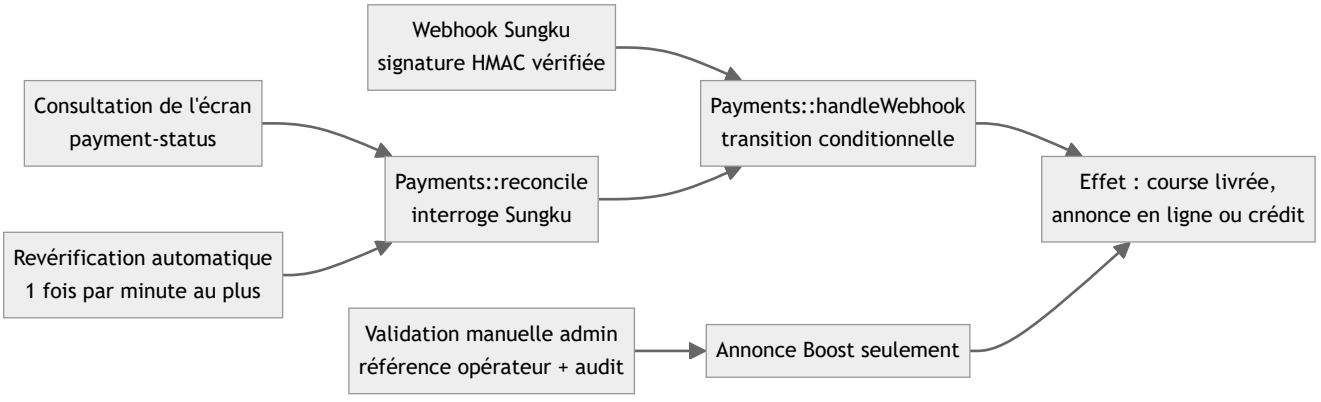
Livraison avec code unique et paiement



Le destinataire n'utilise pas l'application. La course n'est clôturée qu'à la confirmation de paiement.

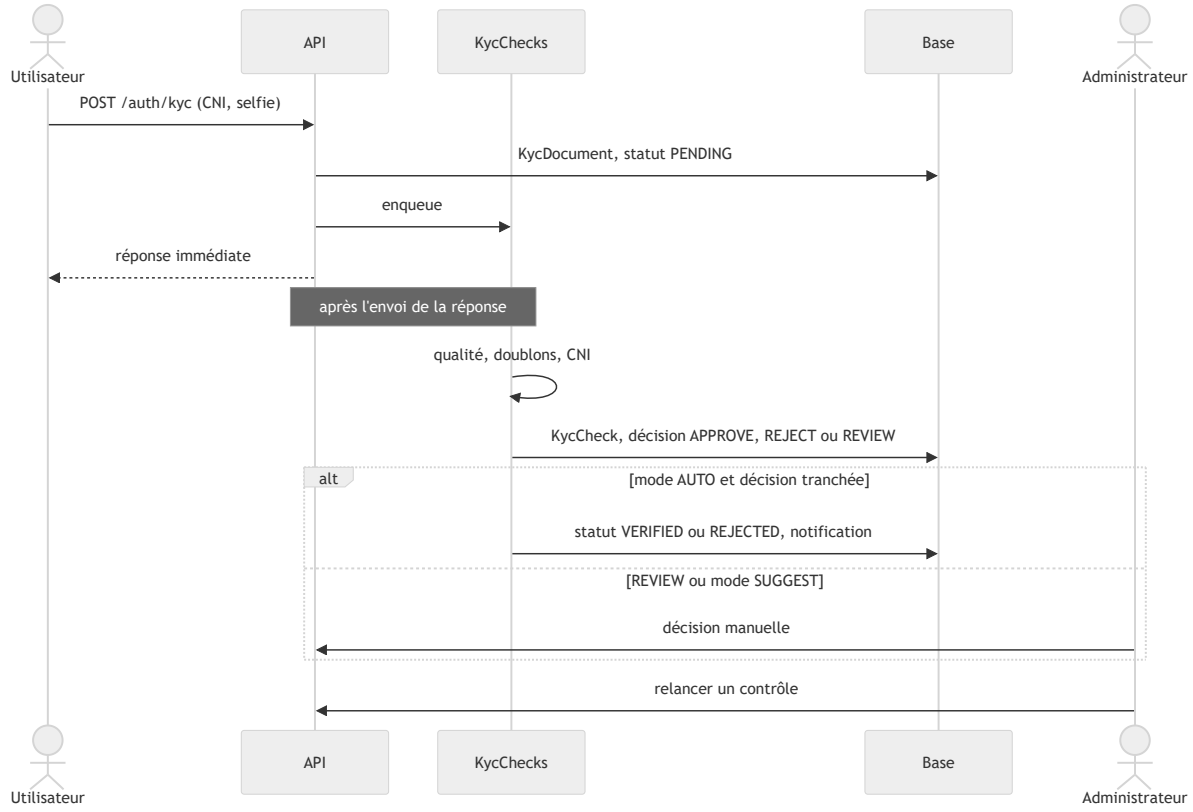
Confirmation d'un paiement : trois chemins

Le webhook est le chemin normal. Comme il peut ne pas arriver, deux rattrapages existent, qui passent par le même code de traitement idempotent.



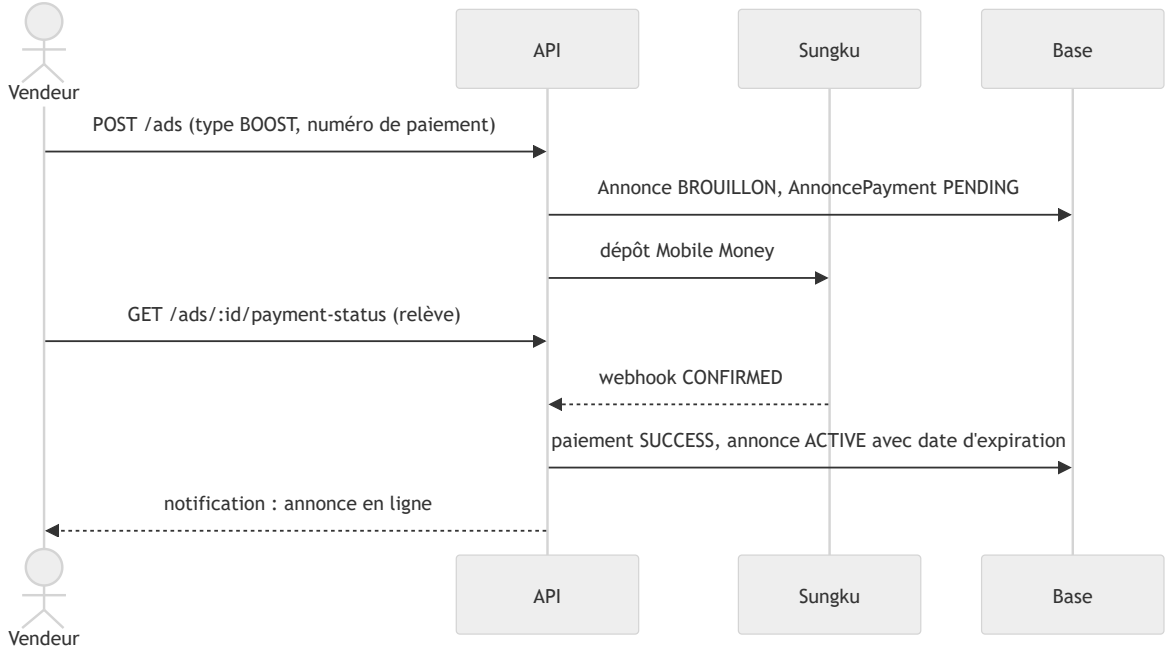
Les trois chemins de confirmation et la validation manuelle, réservée aux paiements Boost.

Vérification KYC automatique



Il n'y a ni reconnaissance faciale ni lecture de texte : le contrôle automatique vérifie la qualité des images, les doublons et le numéro de CNI.

Annonce Boost



Un Boost est payé avant la mise en ligne et n'est pas remboursable. Une annonce Flash est gratuite et dure 24 heures.

10 Tarification et règles métier

Le vendeur propose trois prix croissants. Le livreur choisit un niveau, ou demande un nouveau prix au retrait si le colis diffère. Les valeurs ci-dessous sont les valeurs par défaut ; toutes se modifient au back-office, sauf mention.

RÈGLE	VALEUR PAR DÉFAUT	OÙ LA CHANGER
Commission de la plateforme	3 % du prix, prélevée sur la part du livreur	Tarification
Plancher des prix proposés	500 F	Tarification
Frais d'annulation (refus du nouveau prix)	500 F, versés au livreur	Tarification
Délai de réponse du vendeur	10 minutes	Tarification
Incidents avant suspension	3 incidents confirmés, sur toute la durée	Tarification
Trajets à prix fixe	Par couple départ-arrivée, avec supplément au-delà d'un poids léger	Trajets fixes
Annonce Flash	Gratuite, 24 heures	Annonces, tarifs et limites
Annonce Boost	Payante, durée au choix, non remboursable	Annonces, tarifs et limites

Le calcul historique (base, kilomètres, poids, zone) est conservé comme estimation indicative. La distance vient de OSRM, avec géocodage Nominatim, et chaque paire de lieux est mise en cache (`RouteCache`). Une distance estimée sans appel externe est marquée comme telle.

Un incident signalé par un livreur (poids, taille, valeur, objet interdit, objet dangereux) peut être confirmé ou contesté. Au seuil, le vendeur est suspendu ; il peut faire appel, et l'administrateur peut lever la suspension.

11 Sécurité

SUJET	MÉCANISME
Authentification	Téléphone ou e-mail et PIN. PIN stocké haché. Jeton d'accès et jeton de rafraîchissement signés en HS256 (seul algorithme accepté). Administrateur : e-mail, mot de passe de 6 à 12 chiffres, code par e-mail à la première connexion.
Autorisation	Intergiciels JWT puis rôle (`requireRole`). Un administrateur ne peut pas agir sur un autre administrateur ni sur lui-même pour les PIN et codes.
Limites de débit	Table `RateLimit` : envoi de codes, vérification, connexion, tests SMS et e-mail, par adresse IP et par identifiant.
Codes de vérification	4 chiffres, 5 minutes, 3 essais ; un SMS expiré n'est jamais envoyé en retard (`ttlSeconds`).
Webhook de paiement	Signature `sha256=HMAC(horodatage + "." + corps brut)` avec un secret partagé, comparaison à temps constant. Traitement idempotent.

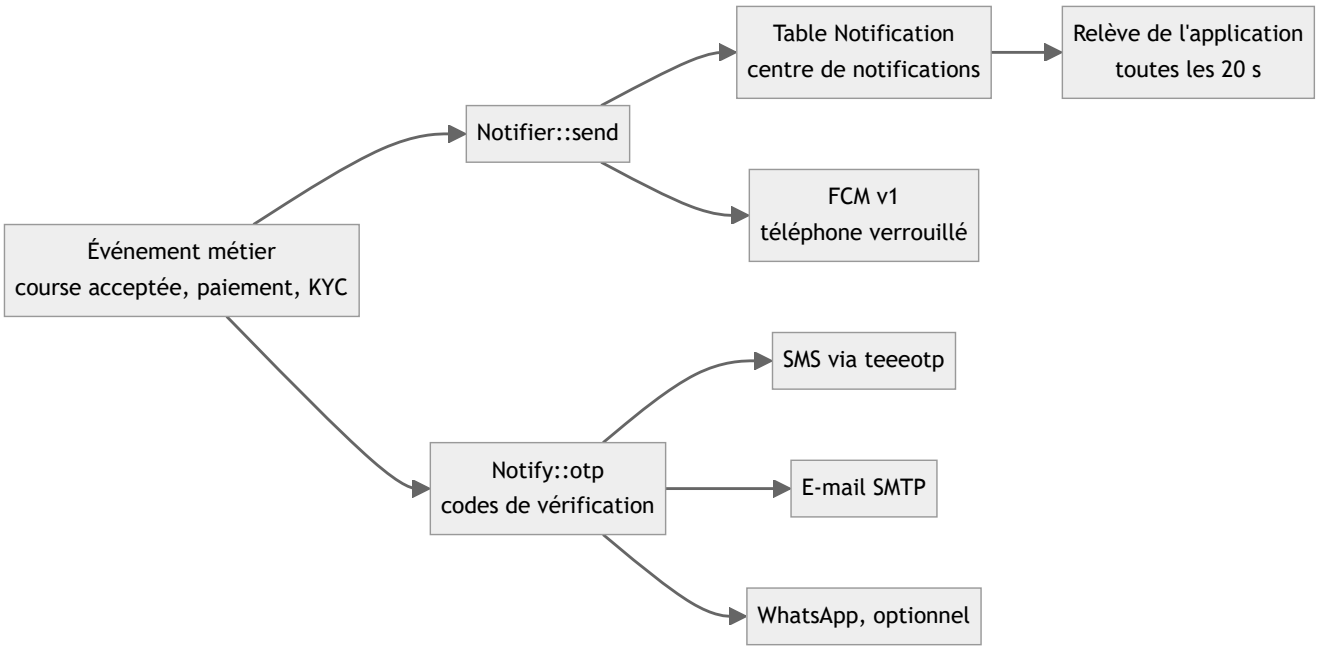
SUJET	MÉCANISME
Argent	Transitions conditionnelles en base, séquestre par course, un échec de paiement n'est jamais conclu sans preuve.
Secrets	Fichier `.env.php` hors du dépôt, clé Firebase dans `app/storage` (accès web refusé), clé SMS en base ou en variable d'environnement, jamais renvoyée par l'API.
Données sensibles	Pièces KYC et photos servies par des routes authentifiées, jamais par une URL publique. Le texte des SMS n'est pas conservé.
Traçabilité	`AdminAction` (PIN, OTP, suspension, clé SMS, validation manuelle de paiement), `DeliveryEvent`, `SmsLog`, `KycCheck`.
Modération	Mots surveillés sur les annonces (mise en attente), signalements, suspension.

Points à surveiller. Tant que `OTP_RETURN_CODE` est actif, le code d'un numéro non inscrit est renvoyé à l'application, ce qui contourne la preuve de possession du numéro : à désactiver quand les SMS sont fiables. Les secrets partagés en clair dans des conversations (accès FTP, base, SMTP, clé Firebase, clé SMS, mot de passe administrateur) doivent être renouvelés.

12 Intégrations externes

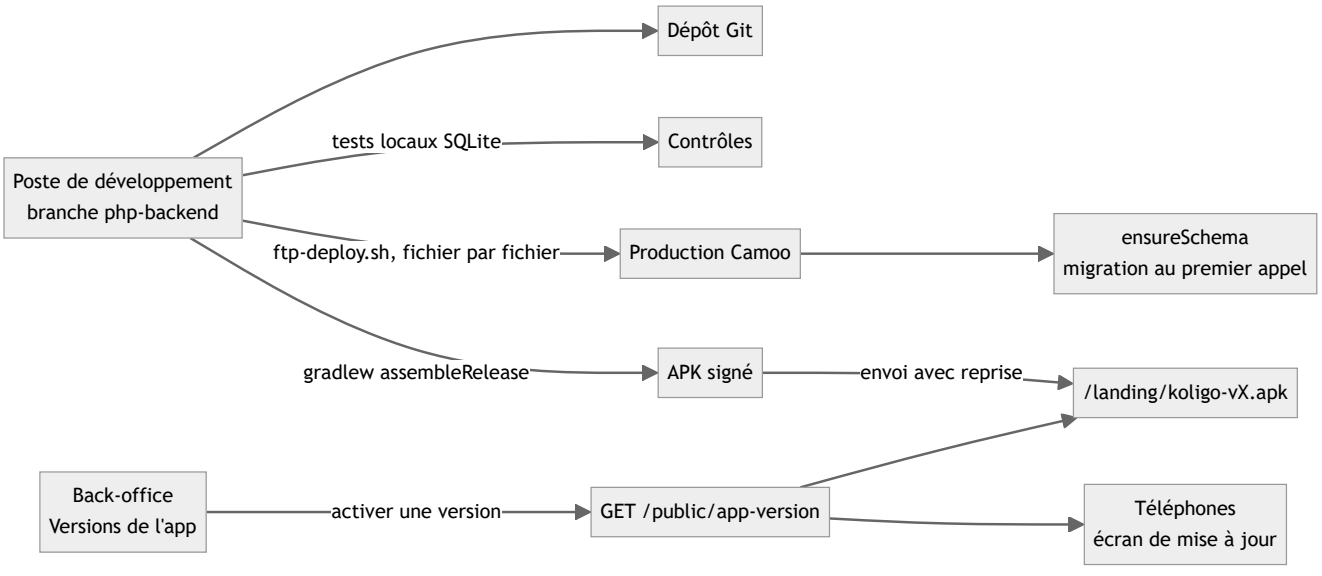
SERVICE	USAGE	INTERFACE	SI LE SERVICE EST INDISPONIBLE
Sungku vers pawaPay, Orange Money et MTN MoMo	Dépôts Mobile Money : course, Boost, recharge	`POST /api/partners/deposits`, `GET …/deposits/{id}`, clé API. Webhook entrant signé (`X-Sungku-*`).	Paiement laissé PENDING, rattrapé par revérification
Firebase Cloud Messaging	Notifications sur le téléphone	API HTTP v1, jeton OAuth obtenu avec un compte de service (JWT RS256), mis en cache environ 50 minutes	Notification visible dans l'application (relève toutes les 20 s)
teeeotp passerelle SMS TRU GROUP	Codes de vérification et SMS	`POST /v1/sms`, `GET /v1/sms/{id}`, `GET /v1/me`, clé `X-Api-Key`. Un téléphone Android avec SIM envoie les messages.	Erreur codifiée, journal `SmsLog`, canal e-mail en parallèle
SMTP ewodi.net	E-mails (codes, bienvenue, livraisons)	Port 587, STARTTLS, authentification. Messages texte et HTML.	Repli sur `mail()` de l'hébergeur
Nominatim et OSRM	Géocodage et distances par la route	HTTP, cache en base	Distance estimée, marquée comme telle
Infobip WhatsApp	Messages WhatsApp, si configuré	API HTTP, clé	Ignoré en silence

Notifications : trois canaux



Les notifications sont toujours enregistrées en base, puis poussées au téléphone si possible. Les codes de vérification suivent un chemin séparé, par SMS, e-mail et WhatsApp.

13 Déploiement et exploitation



Du poste de développement à la production, et la boucle de mise à jour imposée aux téléphones.

Mise à jour imposée aux applications installées

La table `AppVersion` garde l'historique des APK. Une seule version est active. Au démarrage puis toutes les 60 secondes, l'application envoie son numéro de build ; si celui-ci diffère de la version active, elle affiche un écran bloquant (mise à jour obligatoire) ou une simple invitation (facultative). Activer une ancienne version provoque un retour arrière : Android refuse

d'installer un build plus ancien par-dessus un plus récent, l'utilisateur doit donc désinstaller puis réinstaller. La page de téléchargement du site suit la version active.

Observabilité

BESOIN	OUTIL
Paiements Boost en attente	Back-office, Annonces, Paiements Boost : statut, dernière réponse brute de Sungku, dernier appel de confirmation reçu, revérification et validation manuelle
SMS	Back-office, Notifications : clé, quota du projet, journal avec état relevé chez teeeotp et raison des échecs
E-mail	Back-office, Notifications : mode d'envoi et test avec l'erreur réelle du serveur SMTP
Notifications push	Route `/admin/push-status` : clé Firebase présente, jeton obtenu, appareils enregistrés
KYC	Historique des contrôles automatiques et relance
Erreurs serveur	Journal PHP dans `app/storage/logs` (non lisible depuis le web)

Tests

Le dépôt contient `tests/api_test.php` (API complète en local), `kyc_checks_test.php` (29 contrôles du moteur KYC), `app_versions_test.php` (16 contrôles de la gestion des versions) et un faux serveur Sungku. Un test de fumée contre la production existe (`smoke_prod.php`). Aucun test automatisé ne couvre l'application mobile ni le back-office.

14 Dette technique et risques

SUJET	RISQUE	PISTE
Déploiement FTP	Instable, déploiements partiels possibles, pas de retour arrière automatique du code serveur	Hébergement avec SSH ou intégration continue, déploiement atomique
Pas de tâche planifiée	Les travaux différés dépendent de l'activité des utilisateurs	Tâche cron si l'hébergeur la permet, sinon service externe qui appelle une route
SMS par un téléphone Android	Un téléphone éteint ou hors ligne bloque tous les SMS ; une seule SIM, quelques centaines de SMS par jour	Second téléphone, ou agrégateur SMS pour un nom d'expéditeur « KoliGo »
Délivrabilité des e-mails	SPF neutre (`?all`), aucun enregistrement DMARC : risque de spam	SPF avec `~all` , DMARC, vérifier la signature DKIM
Secrets	Plusieurs secrets ont été partagés en clair	Renouveler : FTP, base, SMTP, Firebase, teeeotp, mot de passe administrateur
Code de vérification renvoyé	`OTP_RETURN_CODE` contourne la preuve du numéro	Désactiver une fois les SMS fiables
Tests	Pas de test mobile ni back-office ; la suite de non-régression complète n'est pas versionnée	Versionner la suite, ajouter des tests de bout en bout
Traduction	Le fulfulde est presque vide (3 textes sur 668)	Page « Traductions » au back-office avec relecture par un locuteur

SUJET	RISQUE	PISTE
Ancien serveur Node	Code mort dans le dépôt	Archiver ou supprimer
Une seule base, pas de réplication	Une panne de l'hébergeur arrête tout	Sauvegardes régulières hors hébergeur

Je n'ai pas pu vérifier depuis le code : la politique de sauvegarde de la base en production, la configuration exacte du serveur (versions de PHP et de MySQL, limites mémoire), ni la présence d'un monitoring externe.

15 Annexes

Groupes de routes

PRÉFIXE	CONTENU	ACCÈS
`/public/*`	Villes, tarifs, devis, distance, configuration, CGU, version de l'application, annonces publiques	Libre (annonces : jeton facultatif)
`/auth/*`	Codes, inscription, connexion, rafraîchissement, PIN oublié, KYC, connexion administrateur	Libre ou jeton
`/user/*`, `/notifications`	Profil, PIN, notifications	Jeton
`/deliveries/*`	Publier, lister, accepter, retrait, arrivée, encaissement, prix, incidents, chat, notes	Jeton, rôle vendeur ou livreur
`/ads/*`	Annonces du vendeur, paiement Boost, signalements	Jeton
`/wallet/*`, `/payment/*`	Portefeuille, recharges, retraits, webhook Sungku	Jeton (webhook : signature)
`/admin/*`	Tout le back-office	Jeton, rôle administrateur

Glossaire

XAF, F

Franc CFA, sans décimales.

Séquestre (escrow)

Montant bloqué à la publication d'une course et libéré à la livraison ou à l'annulation.

Gabarit

Taille déclarée du colis, qui influe sur le prix.

Flash, Boost

Annonces gratuites de 24 heures, annonces payantes de durée choisie.

KYC

Vérification d'identité : CNI et selfie.

Webhook

Appel envoyé par un service externe à notre serveur pour annoncer un résultat.

Idempotent

Qui peut être rejoué sans produire d'effet supplémentaire.

Surcharge de méthode

Envoyer POST en indiquant la méthode voulue dans un en-tête, quand l'hébergeur refuse PUT, PATCH et DELETE.

Spécifications du dépôt

- `specs/001-koligo-monorepo`, `002-tarification-gabarits-colis`, `003-annonces-flash-boost`, `004-prix-propose-negociation`
- `backend-php/README.md` : installation locale, déploiement, contraintes de l'hébergement
- `docs/traduction-fulfulde.csv` : textes à traduire